

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



**TIỂU LUẬN KẾT THÚC HỌC PHẦN
BẢO MẬT IoT**

QUẢN LÝ RỦI RO BẢO MẬT CHO HỆ THỐNG IoT QUY MÔ NHỎ

Giảng viên hướng dẫn: Hồ Nhật Minh

Lớp học phần: INT4410

Sinh viên thực hiện: Võ Nguyễn Duyên

Mã số sinh viên: 231A010722

TP. HỒ CHÍ MINH

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN**



**TIỂU LUẬN KẾT THÚC HỌC PHẦN
BẢO MẬT IoT**

QUẢN LÝ RỦI RO BẢO MẬT CHO HỆ THỐNG IoT QUY MÔ NHỎ

Giảng viên hướng dẫn: Hồ Nhật Minh

Lớp học phần: INT4410

Sinh viên thực hiện: Võ Nguyễn Duyên

Mã số sinh viên: 231A010722

TP. HỒ CHÍ MINH

TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO TIỂU LUẬN CUỐI KỲ

HỌC PHẦN: BẢO MẬT IoT

TÊN ĐỀ TÀI

QUẢN LÝ RỦI RO BẢO MẬT CHO HỆ THỐNG IoT QUY MÔ NHỎ

Mã học phần	INT4410
Lớp học phần	
Giảng viên hướng dẫn	Hồ Nhật Minh
Sinh viên/Nhóm	Võ Nguyễn Duyên
Thành viên - MSSV	Võ Nguyễn Duyên - 231A010722
Link repo GitHub	vonguyenduyen512-oss/231A010722-vo-nguyen-duyen-quan-ly-rui-ro-iot: Báo cáo tiểu luận cuối kỳ - Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ
Ngày nộp	24/07/2026

TP. HỒ CHÍ MINH, 2026

LỜI CẢM ƠN

Sau thời gian học tập và thực hiện tiểu luận môn **Bảo mật IoT**, em đã hoàn thành đề tài **"Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ"**. Để hoàn thành bài tiểu luận này, em đã nhận được sự hướng dẫn và hỗ trợ từ thầy cùng nhà trường.

Em xin chân thành cảm ơn **Thầy Hồ Nhựt Minh** đã tận tình giảng dạy, chia sẻ những kiến thức bổ ích và hướng dẫn em trong suốt quá trình học tập cũng như thực hiện đề tài. Những góp ý của thầy đã giúp em hiểu rõ hơn về quản lý rủi ro bảo mật trong hệ thống IoT và hoàn thiện bài tiểu luận của mình.

Em cũng xin cảm ơn quý Thầy, Cô Khoa Công nghệ Thông tin, Trường Đại học Văn Hiến đã truyền đạt những kiến thức nền tảng và tạo điều kiện để em được học tập trong môi trường tốt.

Trong quá trình thực hiện bài tiểu luận, mặc dù em đã cố gắng tìm hiểu tài liệu, tổng hợp kiến thức và hoàn thành bài làm một cách nghiêm túc, nhưng do kiến thức và kinh nghiệm thực tế còn hạn chế nên bài tiểu luận chắc chắn vẫn còn những thiếu sót. Em rất mong nhận được những ý kiến đóng góp của quý Thầy, Cô để em có thể rút kinh nghiệm và hoàn thiện bản thân hơn trong quá trình học tập cũng như nghiên cứu sau này.

Cuối cùng, em xin kính chúc quý Thầy, Cô luôn dồi dào sức khỏe, hạnh phúc và đạt nhiều thành công trong công tác giảng dạy.

TP..Hồ Chí Minh, ngày.....tháng.....năm.....

Sinh viên thực hiện

NHẬN XÉT CỦA GIẢNG VIÊN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

TP. Hồ Chí Minh, ngày.....tháng.....năm.....

Giảng viên bộ môn

MỤC LỤC

1. MỞ ĐẦU	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Phát biểu vấn đề	1
1.3. Mục tiêu	1
1.4. Đối tượng và phạm vi	1
1.5. Sản phẩm dự kiến và đóng góp	1
2. CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN	2
2.1. Kiến trúc, giao thức hoặc công nghệ nền	2
2.2. Khái niệm bảo mật liên quan	2
2.3. Chuẩn, tài liệu và công cụ GitHub	4
2.4. Công trình/giải pháp liên quan	4
3. PHƯƠNG PHÁP VÀ THIẾT KẾ	4
3.1. Phương pháp thực hiện	4
3.2. Kiến trúc/mô hình và luồng dữ liệu	5
3.3. Môi trường, công cụ và dữ liệu	5
3.4. Quy trình thực hiện	5
3.5. Giới hạn an toàn và đạo đức	6
4. TRIỂN KHAI VÀ SẢN PHẨM	6
4.1. Chuẩn bị môi trường	6
4.2. Thành phần sản phẩm	7
4.3. Kịch bản thử nghiệm/đánh giá	7
4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm	7
5. KẾT QUẢ VÀ THẢO LUẬN	7
5.1. Kết quả chính	7
5.2. Bảng tổng hợp kết quả	9
5.3. Đối chiếu mục tiêu	9
5.4. Hạn chế	9
6. ĐÁNH GIÁ BẢO MẬT	10
6.1. Tài sản và dữ liệu cần bảo vệ	10
6.2. Mối đe dọa và lỗ hổng	10
6.3. Ma trận rủi ro	11
6.4. Biện pháp giảm thiểu và ưu tiên	11
6.5. Đánh giá an toàn sau xử lý	12
7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	13
7.1. Kết luận	13
7.2. Hướng phát triển	13
TÀI LIỆU THAM KHẢO	14

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP	15
PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP	15
PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP	15

DANH MỤC BẢNG

Bảng 6.1. Tài sản và dữ liệu cần bảo vệ

Bảng 6.2. Mối đe dọa và lỗ hổng

Bảng 6.3. Ma trận rủi ro

Bảng 6.4. Checklist kiểm tra bảo mật định kỳ

DANH MỤC HÌNH ẢNH

Hình 2.1. Kiến trúc tổng thể hệ thống IoT quy mô nhỏ

Hình 2.2. Quy trình quản lý rủi ro

Hình 3.1. Kiến trúc đề xuất của hệ thống IoT quy mô nhỏ

Hình 3.2. Quy trình triển khai đánh giá rủi ro

Hình 5.1. Kết quả lập danh mục tài sản của hệ thống IoT

Hình 5.2. Kết quả xây dựng Risk Register

Hình 5.3. Ma trận đánh giá rủi ro 5×5

DANH MỤC TỪ VIẾT TẮT

Viết tắt	Ý nghĩa
IoT	Internet of Things
CIA	Confidentiality – Integrity – Availability
MFA	Multi-Factor Authentication
VPN	Virtual Private Network
TLS	Transport Layer Security
HTTPS	HyperText Transfer Protocol Secure
MQTT	Message Queuing Telemetry Transport
OWASP	Open Worldwide Application Security Project
NIST	National Institute of Standards and Technology
ISVS	IoT Security Verification Standard

1. MỞ ĐẦU

1.1. Bối cảnh và lý do chọn đề tài

Internet of Things (IoT) đang phát triển mạnh mẽ và được ứng dụng rộng rãi trong nhiều lĩnh vực như nhà thông minh, nông nghiệp, y tế, giáo dục và doanh nghiệp. Các thiết bị IoT có khả năng thu thập, truyền tải và xử lý dữ liệu theo thời gian thực, góp phần nâng cao hiệu quả quản lý và tối ưu chi phí vận hành.

Tuy nhiên, các hệ thống IoT quy mô nhỏ vẫn tiềm ẩn nhiều nguy cơ mất an toàn thông tin do hạn chế về chi phí và khả năng quản trị. Nhiều thiết bị còn sử dụng mật khẩu mặc định, chưa cập nhật firmware thường xuyên, thiếu cơ chế xác thực và mã hóa dữ liệu, làm tăng nguy cơ truy cập trái phép, rò rỉ dữ liệu và bị tấn công mạng.

Theo OWASP Internet of Things Security Project (2024), các lỗ hổng phổ biến của IoT gồm mật khẩu mặc định, cấu hình không an toàn và thiếu cơ chế cập nhật firmware. NIST SP 800-30 Revision 1 (2012) cũng khuyến nghị đánh giá rủi ro thông qua việc nhận diện tài sản, xác định mối đe dọa, đánh giá tác động và đề xuất biện pháp giảm thiểu.

Xuất phát từ thực tế trên, đề tài "Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ" được thực hiện nhằm nhận diện tài sản, phân tích mối đe dọa và lỗ hổng bảo mật, đánh giá mức độ rủi ro, từ đó đề xuất các biện pháp giảm thiểu phù hợp với điều kiện triển khai thực tế.

1.2. Phát biểu vấn đề

Hệ thống IoT quy mô nhỏ gồm nhiều tài sản quan trọng như thiết bị IoT, dữ liệu cảm biến, firmware, tài khoản quản trị và hạ tầng mạng. Do hạn chế về chi phí và khả năng quản trị, các hệ thống này thường tồn tại nhiều lỗ hổng như mật khẩu yếu, firmware chưa cập nhật, thiếu cơ chế mã hóa và xác thực, làm gia tăng nguy cơ truy cập trái phép, rò rỉ dữ liệu và tấn công mạng.

Nếu không được đánh giá và kiểm soát kịp thời, các rủi ro này sẽ ảnh hưởng đến tính bí mật, tính toàn vẹn và tính sẵn sàng của hệ thống. Vì vậy, đề tài tập trung xây dựng mô hình quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ thông qua việc nhận diện tài sản, xác định mối đe dọa, xây dựng Risk Register, đánh giá rủi ro bằng ma trận 5×5 và đề xuất các biện pháp giảm thiểu phù hợp.

1.3. Mục tiêu

Đề tài được thực hiện nhằm đạt được các mục tiêu sau:

MT-01: Xác định và phân loại các tài sản quan trọng trong hệ thống IoT quy mô nhỏ.

MT-02: Phân tích các mối đe dọa, lỗ hổng và đánh giá mức độ rủi ro đối với từng tài sản.

MT-03: Xây dựng Risk Register và ma trận đánh giá rủi ro 5×5 .

MT-04: Đề xuất các biện pháp xử lý và giảm thiểu rủi ro có mức độ cao.

MT-05: Xây dựng checklist kiểm tra bảo mật định kỳ cho hệ thống IoT.

1.4. Đối tượng và phạm vi

Đối tượng nghiên cứu: Hệ thống IoT quy mô nhỏ gồm thiết bị IoT, gateway, dữ liệu cảm biến, tài khoản quản trị và hạ tầng mạng.

Phạm vi nghiên cứu: Đề tài đánh giá rủi ro trên mô hình IoT giả lập, tham khảo các tiêu chuẩn OWASP IoT Security Project và NIST SP 800-30 để đề xuất giải pháp bảo mật.

Giới hạn nghiên cứu: Đề tài không thực hiện tấn công trên thiết bị IoT thực tế, không thu thập dữ liệu cá nhân và chỉ tập trung vào việc nhận diện, đánh giá và quản lý rủi ro bảo mật.

1.5. Sản phẩm dự kiến và đóng góp

Sau khi hoàn thành, đề tài dự kiến đạt được các sản phẩm sau:

- Sơ đồ kiến trúc tổng thể của hệ thống IoT quy mô nhỏ.
- Danh sách các tài sản cần bảo vệ trong hệ thống.
- Risk Register gồm tối thiểu 6 rủi ro bảo mật.
- Ma trận đánh giá rủi ro 5×5.
- Kế hoạch xử lý và giảm thiểu đối với toàn bộ 6 rủi ro theo mức độ ưu tiên.
- Checklist kiểm tra bảo mật định kỳ cho hệ thống IoT.
- README mô tả phạm vi nghiên cứu, nguồn tài liệu tham khảo và hướng dẫn sử dụng các sản phẩm của đề tài.

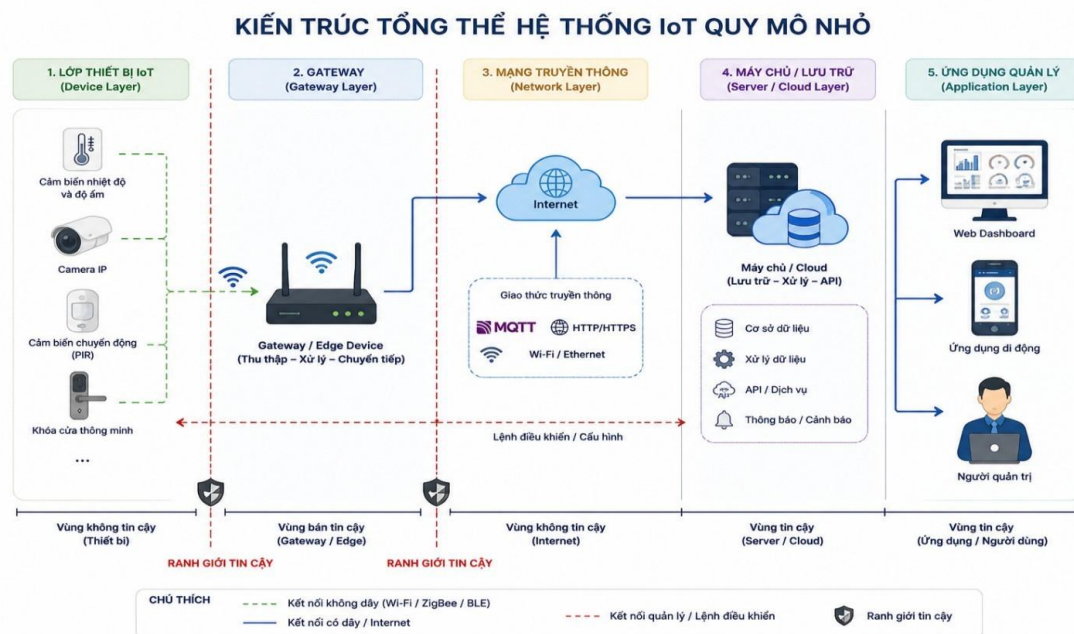
2. CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN

2.1. Kiến trúc, giao thức hoặc công nghệ nền

Hệ thống IoT quy mô nhỏ trong phạm vi đề tài được xây dựng theo mô hình gồm 5 thành phần chính: lớp thiết bị IoT, gateway, mạng truyền thông, máy chủ/lưu trữ và ứng dụng quản lý (Hình 2.1). Đây là mô hình phổ biến trong các hộ gia đình, phòng thí nghiệm và doanh nghiệp nhỏ, cho phép thu thập, truyền tải và quản lý dữ liệu từ các thiết bị IoT.

Ở lớp thiết bị, các cảm biến, camera IP và khóa thông minh thực hiện thu thập dữ liệu hoặc điều khiển thiết bị. Dữ liệu được gateway tiếp nhận, xử lý sơ bộ và truyền qua mạng bằng các giao thức như MQTT hoặc HTTP/HTTPS đến máy chủ để lưu trữ, xử lý và cung cấp dịch vụ. Người quản trị có thể giám sát và điều khiển hệ thống thông qua giao diện web hoặc ứng dụng di động.

Trong kiến trúc này, dữ liệu truyền giữa các thành phần cần được bảo vệ bằng các cơ chế xác thực, mã hóa và kiểm soát truy cập nhằm hạn chế nguy cơ truy cập trái phép, nghe lén hoặc giả mạo dữ liệu. Các ranh giới tin cậy trong hệ thống cũng là cơ sở để xác định tài sản và đánh giá rủi ro.



Hình 2.1. Kiến trúc tổng thể hệ thống IoT quy mô nhỏ. Nguồn: ChatGPT (OpenAI), nhóm tác giả hiệu chỉnh (2026).

2.2. Khái niệm bảo mật liên quan

Tài sản (Asset): Tài sản là những thành phần có giá trị cần được bảo vệ trong hệ thống. Đối với hệ thống IoT, tài sản bao gồm thiết bị IoT, gateway, dữ liệu cảm biến, tài khoản quản trị, firmware, khóa mã hóa và hạ tầng mạng.

Mối đe dọa (Threat): Mối đe dọa là các sự kiện hoặc hành động có khả năng khai thác điểm yếu của hệ thống và gây ảnh hưởng đến hoạt động bình thường. Một số mối đe dọa phổ biến gồm truy cập trái phép, giả mạo thiết bị, phát tán mã độc, tấn công từ chối dịch vụ (DoS) và nghe lén dữ liệu.

Lỗ hổng (Vulnerability): Lỗ hổng là điểm yếu tồn tại trong thiết bị, phần mềm hoặc quy trình quản lý có thể bị kẻ tấn công khai thác. Ví dụ như sử dụng mật khẩu mặc định, firmware chưa cập nhật, cấu hình sai hoặc giao tiếp không được mã hóa.

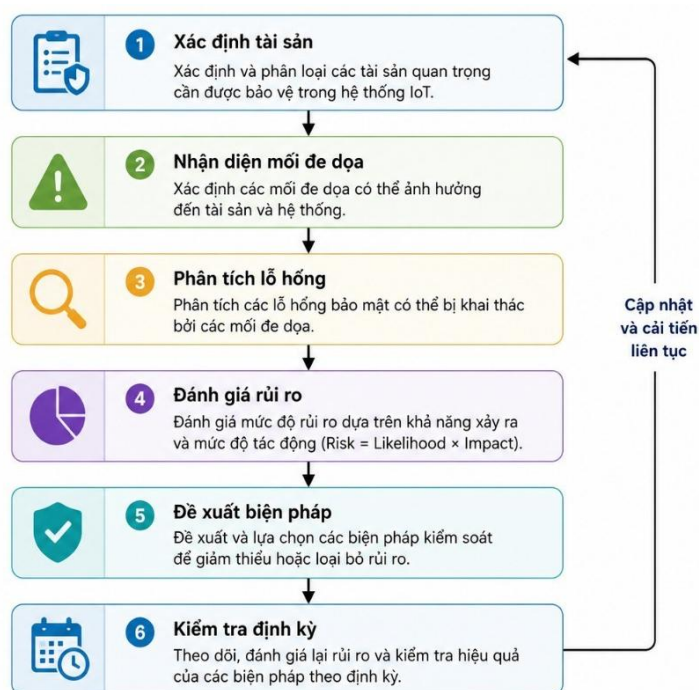
Rủi ro (Risk): Rủi ro là khả năng xảy ra sự cố bảo mật khi một mối đe dọa khai thác thành công lỗ hổng của hệ thống và gây ra thiệt hại đối với tài sản. Trong đề tài, mức độ rủi ro được đánh giá theo công thức: $Risk = Likelihood \times Impact$, trong đó Likelihood là khả năng xảy ra và Impact là mức độ ảnh hưởng của sự cố.

Mô hình CIA gồm ba thuộc tính cơ bản: Confidentiality (tính bí mật) đảm bảo dữ liệu chỉ được truy cập bởi các đối tượng được phép; Integrity (tính toàn vẹn) đảm bảo dữ liệu không bị thay đổi trái phép trong quá trình lưu trữ hoặc truyền tải; Availability (tính sẵn sàng) đảm bảo hệ thống luôn sẵn sàng phục vụ người dùng khi cần thiết.

Xác thực và phân quyền: Xác thực (Authentication) là quá trình kiểm tra danh tính của người dùng hoặc thiết bị trước khi cho phép truy cập hệ thống. Sau khi xác thực thành công, cơ chế phân quyền (Authorization) sẽ quyết định các chức năng mà người dùng được phép thực hiện.

Firmware: Firmware là chương trình điều khiển được cài đặt trực tiếp trên thiết bị IoT. Nếu firmware tồn tại lỗ hổng hoặc không được cập nhật định kỳ, thiết bị dễ bị khai thác; do đó firmware cần được cập nhật thường xuyên để khắc phục lỗ hổng bảo mật.

Đề tài thuộc Hướng G – Quản trị rủi ro, chính sách, checklist và kiểm thử, vì vậy nội dung được vận dụng theo một quy trình quản lý rủi ro gồm các bước: xác định tài sản, nhận diện mối đe dọa và lỗ hổng, đánh giá mức độ rủi ro, đề xuất biện pháp giảm thiểu và kiểm tra định kỳ (Hình 2.2). Quy trình này là khung tham chiếu xuyên suốt cho Chương 3 và Chương 6 của báo cáo.



Hình 2.2. Quy trình quản lý rủi ro. Nguồn: ChatGPT (OpenAI), nhóm tác giả hiệu chỉnh (2026).

2.3. Chuẩn, tài liệu và công cụ GitHub

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
1	OWASP IoT Security Verification Standard (ISVS)	github.com/OWASP/IoT-Security-Verification-StandardISVS	Khung yêu cầu bảo mật (communication, software, hardware, data protection) dùng để xây dựng risk register và checklist kiểm tra định kỳ	04/07/2026
2	OWASP IoT Security Testing Guide (ISTG)	github.com/OWASP/owasp-istg	Tham khảo phương pháp/quy trình kiểm tra từng hạng mục trong checklist	04/07/2026
3	OWASP Internet of Things Project	github.com/OWASP/www-project-internetof-things	Tổng hợp OWASP IoT Top 10 – nhóm rủi ro phổ biến dùng làm cơ sở xác định mối đe dọa/lỗ hổng trong risk register	04/07/2026
4	Practical IoT Security (B. Russell, D. Van Duren, Packt, 2016)	— (sách in)	thành phần rủi ro (tài sản – mối đe dọa – lỗ hổng)	—
5	IoT Security Guidelines Ver. 1.0 – IoT Acceleration Consortium, MIC, METI (2016)	— (tài liệu chính phủ Nhật Bản)	Tham khảo khung hướng dẫn bảo mật IoT tổng quát	—
6	Node-RED (node-red community)	github.com/node-red/node-red	Tham khảo vai trò gateway trong mô hình hệ thống (không dùng code demo)	04/07/2026

2.4. Công trình/giải pháp liên quan

Đề tài kế thừa các hướng dẫn của OWASP và NIST để xây dựng mô hình quản lý rủi ro phù hợp với hệ thống IoT quy mô nhỏ, bao gồm nhận diện tài sản, phân tích mối đe dọa, xây dựng Risk Register, đánh giá rủi ro theo ma trận 5×5 và đề xuất các biện pháp giảm thiểu.

3. PHƯƠNG PHÁP VÀ THIẾT KẾ

Chương này trình bày phương pháp nghiên cứu, mô hình hệ thống, môi trường triển khai và quy trình đánh giá rủi ro được sử dụng trong đề tài. Nội dung được xây dựng dựa trên các hướng dẫn của OWASP IoT Security Project, OWASP IoT Security Verification Standard (ISVS) và NIST SP 800-

30 nhằm đảm bảo quá trình đánh giá rủi ro có tính hệ thống, phù hợp với các hệ thống IoT quy mô nhỏ.

3.1. Phương pháp thực hiện

Đề tài áp dụng phương pháp quản lý rủi ro bảo mật kết hợp với phương pháp phân tích định tính (Qualitative Risk Assessment) để nhận diện và đánh giá các nguy cơ đối với hệ thống IoT quy mô nhỏ. Phương pháp này phù hợp với các hệ thống có quy mô nhỏ, số lượng thiết bị không lớn và chưa có đầy đủ dữ liệu thống kê để thực hiện đánh giá định lượng.

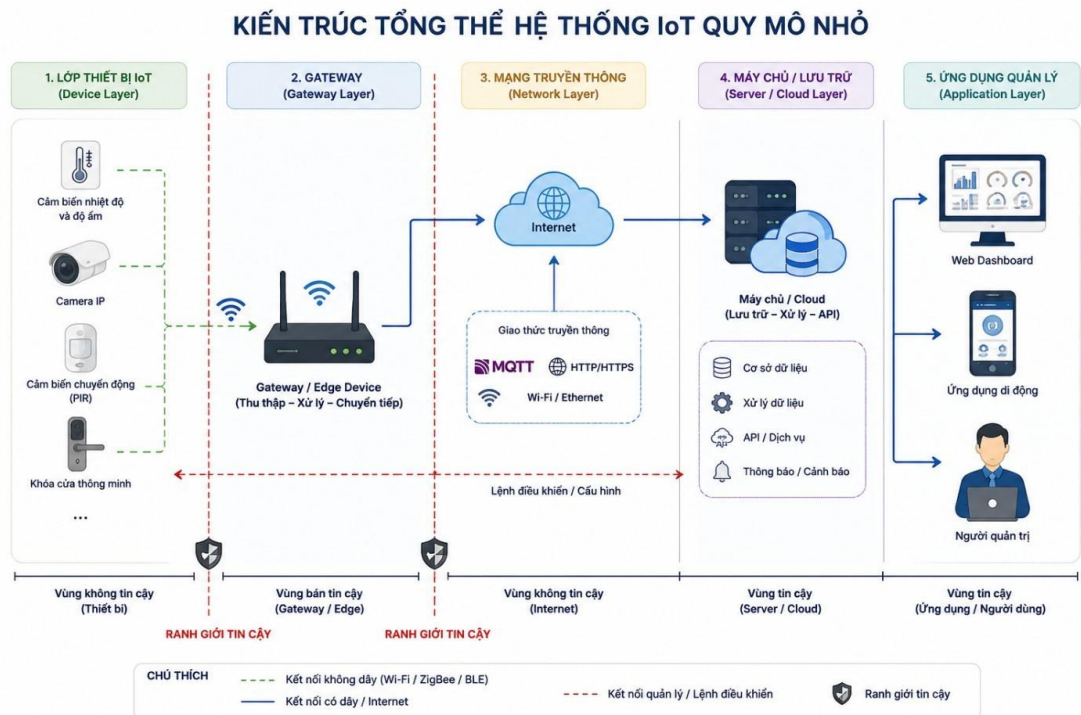
Việc đánh giá rủi ro được thực hiện theo hướng tiếp cận dựa trên tài sản (Asset-Based Risk Assessment), trong đó mỗi tài sản sẽ được phân tích dựa trên các mối đe dọa, lỗ hổng và tác động có thể xảy ra nhằm xác định mức độ ưu tiên xử lý.

3.2. Kiến trúc/mô hình và luồng dữ liệu

Mô hình nghiên cứu của đề tài mô phỏng một hệ thống IoT quy mô nhỏ gồm các thành phần cơ bản như thiết bị IoT, gateway, mạng truyền thông, máy chủ quản lý và người quản trị hệ thống. Đây là mô hình phổ biến được triển khai trong các hộ gia đình, phòng thí nghiệm và doanh nghiệp nhỏ.

Luồng truyền dữ liệu của hệ thống: Thiết bị IoT → Gateway → Server/Cloud → Ứng dụng quản lý → Người quản trị.

Để đảm bảo an toàn thông tin, đề tài xem xét các lớp bảo mật chính trong kiến trúc hệ thống gồm: bảo mật thiết bị IoT; bảo mật gateway; bảo mật mạng truyền thông; bảo mật máy chủ và cơ sở dữ liệu; bảo mật ứng dụng quản lý; quản lý người dùng và phân quyền truy cập.



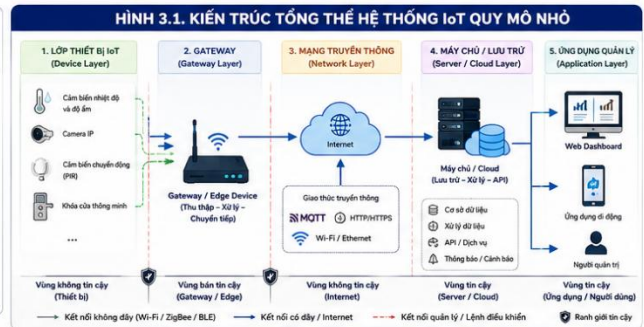
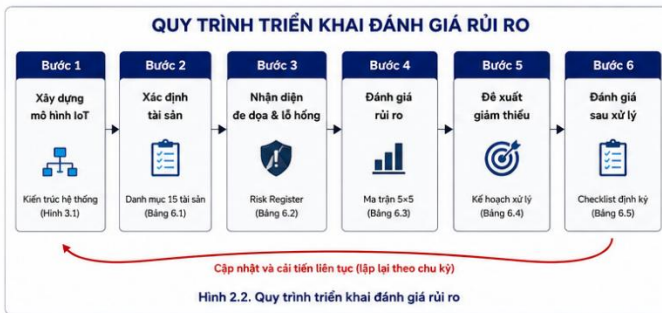
Hình 3.1. Kiến trúc đề xuất của hệ thống IoT quy mô nhỏ. Nguồn: ChatGPT (OpenAI), nhóm tác giả hiệu chỉnh (2026).

3.3. Môi trường, công cụ và dữ liệu

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
Microsoft Word	365	Soạn thảo báo cáo	Không chứa dữ liệu nhạy cảm
Draw.io	Online	Vẽ sơ đồ kiến trúc	Chỉ tạo sơ đồ mô phỏng
Microsoft Excel	365	Risk Register, ma trận rủi ro	Không lưu thông tin thật
GitHub	Web	Lưu trữ tài liệu	Không public secret
OWASP ISVS	Latest	Tham khảo bảo mật	Chỉ dùng tài liệu

3.4. Quy trình thực hiện

Bước	Công việc	Đầu ra	Minh chứng trong repo
1	Xây dựng mô hình IoT	Kiến trúc hệ thống	report/Hình 3.1
2	Xác định tài sản	Danh mục 6 tài sản	Bảng 6.1
3	Nhận diện đe dọa và lỗ hổng	Risk Register	Bảng 6.2
4	Đánh giá rủi ro	Ma trận 5×5	Bảng 6.3
5	Đề xuất giảm thiểu	Kế hoạch xử lý	Bảng 6.3
6	Đánh giá sau xử lý	Checklist định kỳ	Mục 6.5, Bảng 6.4



HÌNH 6.1. DANH MỤC TÀI SẢN (ASSET REGISTER)

ID	Tài sản	Loại tài sản	Giá trị (1-5)	Vùng tin cậy	Mô tả ngắn
1	Gateway / Edge Device	Thiết bị	5	Vùng bản tin cậy	Thiết bị trung tâm, thu nhập và chuyển tiếp dữ liệu
2	Camera IP	Thiết bị	4	Vùng không tin cậy	Giám sát hình ảnh
3	Smart Lock	Thiết bị	5	Vùng không tin cậy	Khóa của thông minh
4	PIR Sensor	Thiết bị	3	Vùng không tin cậy	Phát hiện chuyển động
5	Nhiệt độ & Độ ẩm	Thiết bị	3	Vùng không tin cậy	Đo nhiệt độ và độ ẩm
6	Wi-Fi Router	Thiết bị mạng	4	Vùng bản tin cậy	Kết nối mạng nội bộ
7	MQTT Broker	Dịch vụ	4	Vùng tin cậy	Trung gian truyền tin MQTT
8	Web Server / API	Dịch vụ	5	Vùng tin cậy	Cung cấp API và dịch vụ
9	Database	Dữ liệu	5	Vùng tin cậy	Lưu trữ dữ liệu hệ thống
10	Ứng dụng di động	Ứng dụng	3	Vùng tin cậy	Điều khiển và giám sát

HÌNH 6.2. RISK REGISTER

ID	Tài sản	Mối đe dọa	Lỗ hổng	K (1-5)	T (1-5)	Điểm (KxT)	Mức rủi ro
R-01	Camera IP	Truy cập trái phép	Mật khẩu mặc định	4	4	16	Rất cao
R-02	Gateway	Remote Attack	Firmware lỗi thời	4	5	20	Nghiêm trọng
R-03	Tài khoản quản trị	Brute Force	Mật khẩu yếu	4	5	20	Nghiêm trọng
R-04	Smart Lock	Replay Attack	Không chứng thực	3	5	15	Rất cao
R-05	MQTT Broker	Message Injection	Không xác thực	3	4	12	Cao
R-17	Log hệ thống	Xóa log	Không có cơ chế bảo vệ log	2	3	6	Trung bình

K: Khả năng (1-5)
 T: Tác động (1-5)
 T: Tác động (1-5) Trung bình (5-6) Cao (10-14) Rất cao (15-19) Nghiêm trọng (20-25)

HÌNH 6.3. MA TRẬN RỦI RO 5x5

TÁC ĐỘNG (T)	KHẢ NĂNG XẢY RA (K)				
	1 (Rất thấp)	2 (Thấp)	3 (Trung bình)	4 (Cao)	5 (Rất cao)
5 (Rất cao)	5	10	15	20	25
4 (Cao)	4	8	12	16	20
3 (Trung bình)	3	6	9	12	15
2 (Thấp)	2	4	6	8	10
1 (Rất thấp)	1	2	3	4	5

5 (Rất cao)
 4 (Cao)
 3 (Trung bình)
 2 (Thấp)
 1 (Rất thấp)

1 (Rất thấp) 2 (Thấp) 3 (Trung bình) 4 (Cao) 5 (Rất cao)

■ Nghiêm trọng (20-25)
 ■ Rất cao (15-19)
 ■ Cao (10-14)
 ■ Trung bình (5-9)
 ■ Thấp (1-4)

HÌNH 6.4. KẾ HOẠCH XỬ LÝ RỦI RO (5 RỦI RO ƯU TIÊN)

ID	Rủi ro	Mức độ	Biện pháp xử lý	Người thực hiện	Thời hạn	Rủi ro còn lại (kỳ vọng)
1	Gateway không cập nhật firmware định kỳ	Nghiêm trọng	• Cập nhật firmware định kỳ • Kiểm tra trước khi triển khai • Bật cảnh báo phiên bản mới	Admin	30 ngày	Trung bình
2	Tài khoản quản trị mật khẩu yếu, không có MFA	Nghiêm trọng	• Áp dụng MFA • Chính sách mật khẩu mạnh • Khóa tài khoản sau nhiều lần sai	Admin	15 ngày	Thấp
3	Smart Lock bị mở khóa trái phép (replay attack)	Rất cao	• Dùng mã động (rolling code) • Giới hạn khoảng cách kết nối • Cảnh báo mở khóa bất thường	Kỹ thuật	30 ngày	Thấp
4	Camera IP dùng mật khẩu mặc định	Rất cao	• Đổi mật khẩu mặc định • Vô hiệu hóa tài khoản mặc định • Đặt trong VLAN riêng	Kỹ thuật	15 ngày	Trung bình
5	Firmware thiết bị lỗi thời chứa CVE đã công bố	Rất cao	• Vả lỗi ngay khi có bản cập nhật • Thay thế thiết bị không hỗ trợ • Quét lỗ hổng định kỳ	Kỹ thuật	30 ngày	Trung bình

Ưu tiên xử lý: **Nghiêm trọng** → **Rất cao** → **Cao** → **Trung bình** → **Thấp**

HÌNH 6.5. CHECKLIST ĐÁNH GIÁ SAU XỬ LÝ (ĐỊNH KỲ)

Nhóm	Hạng mục kiểm tra	Tần suất	Trạng thái	Ghi chú
Thiết bị IoT	Kiểm tra firmware, cập nhật bản và mới nhất	Hàng tháng	✓	Đã cập nhật v1.2.3
Mạng truyền thông	Kiểm tra dữ liệu truyền có mã hóa TLS/HTTPS	Hàng quý	✓	TLS 1.2+
Tài khoản & truy cập	Kiểm tra chính sách mật khẩu và MFA	Hàng quý	✓	MFA bật
Máy chủ / CSDL	Kiểm tra sao lưu dữ liệu	Hàng tuần	✓	Sao lưu 7 ngày
Giám sát & ứng phó	Kiểm tra hệ thống log/cảnh báo hoạt động	Hàng tuần	✓	Log hoạt động
Con người	Đào tạo nhận thức an toàn thông tin	6 tháng/lần	✓	Đã đào tạo 05/2025

✓ Đạt ✗ Không đạt ⚪ Chưa kiểm tra

Hình 3.2. Quy trình triển khai đánh giá rủi ro. Nguồn: ChatGPT (OpenAI), nhóm tác giả hiệu chỉnh (2026).

3.5. Giới hạn an toàn và đạo đức

Hệ thống chỉ được sử dụng trong môi trường học tập và thử nghiệm, không dùng để tấn công hoặc xâm nhập trái phép vào các hệ thống khác. Dữ liệu sử dụng là dữ liệu mẫu hoặc dữ liệu đã được cho phép. Các thông tin như mật khẩu, tài khoản hoặc khóa bảo mật cần được lưu trữ an toàn và không công khai trong mã nguồn. Người sử dụng phải tuân thủ các quy định về an toàn thông tin và đạo đức nghề nghiệp.

4. TRIỂN KHAI VÀ SẢN PHẨM

4.1. Chuẩn bị môi trường

Quá trình triển khai được thực hiện trên môi trường mô phỏng nhằm đảm bảo an toàn, không tác động đến hệ thống thực tế. Toàn bộ dữ liệu tài sản, mối đe dọa và kịch bản rủi ro được xây dựng dựa

trên khảo sát một mô hình IoT quy mô nhỏ điển hình (hộ gia đình/phòng thí nghiệm), tham chiếu theo hướng dẫn của OWASP và NIST SP 800-30.

4.2. Thành phần sản phẩm

Đề tài đã xây dựng đầy đủ các sản phẩm đề ra tại mục 1.5:

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
1	Sơ đồ kiến trúc	report/	Mô tả hệ thống	Võ Nguyễn Duyên
2	Risk Register	results/	Quản lý rủi ro	Võ Nguyễn Duyên
3	Ma trận 5×5	results/	Đánh giá rủi ro	Võ Nguyễn Duyên
4	Kế hoạch xử lý	results/	Giảm thiểu	Võ Nguyễn Duyên
5	Checklist	results/	Kiểm tra định kỳ	Võ Nguyễn Duyên
6	README	README.md	Hướng dẫn	Võ Nguyễn Duyên

4.3. Kịch bản thử nghiệm/đánh giá

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi	Minh chứng
TC-01	Firmware cũ	Gateway	Đánh giá Risk Register	R-01 mức Nghiêm trọng	Bảng 6.2
TC-02	Mật khẩu yếu	Admin	Đánh giá Risk Register	R-02 mức Nghiêm trọng	Bảng 6.2
TC-03	Replay Attack	Smart Lock	Đánh giá	R-06 mức Rất cao	Bảng 6.2
TC-04	Password mặc định	Camera	Đánh giá	R-03 mức Rất cao	Bảng 6.2
TC-05	Kiểm tra đầy đủ	6 tài sản	Đối chiếu	6 rủi ro	Bảng 6.2

4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm

Các sản phẩm phân tích (Risk Register, ma trận rủi ro, kế hoạch xử lý, checklist) được lưu ở định dạng Excel/Word trong thư mục results/ và report/ của repo. Người dùng mở tệp Risk Register để tra cứu mức độ rủi ro theo từng tài sản, đối chiếu với ma trận 5×5 để xác định thứ tự ưu tiên xử lý, và sử dụng checklist tại Bảng 6.4 theo tần suất tuần/tháng/quý để duy trì việc kiểm tra bảo mật định kỳ. Hướng dẫn chi tiết được mô tả trong README của repo.

5. KẾT QUẢ VÀ THẢO LUẬN

5.1. Kết quả chính

Sau khi hoàn thành đánh giá, hệ thống ghi nhận tổng cộng 6 rủi ro bảo mật trên 6 tài sản, phân bố theo mức độ như sau: 2 rủi ro mức Nghiêm trọng và 4 rủi ro mức Rất cao; không ghi nhận rủi ro mức Cao, Trung bình hoặc Thấp. Kết quả cho thấy nhóm rủi ro liên quan đến xác thực và quản lý truy cập (mật khẩu yếu, thiếu MFA, truy cập từ xa không kiểm soát) và nhóm liên quan đến cập nhật firmware chiếm tỷ trọng cao nhất trong các mức Nghiêm trọng và Rất cao, phù hợp với nhận định của OWASP

IoT Security Project về các lỗ hổng phổ biến của thiết bị IoT. Ma trận rủi ro 5×5 (Bảng 6.3) trực quan hóa sự phân bố này và là cơ sở để xác định thứ tự ưu tiên xử lý toàn bộ 6 rủi ro tại mục 6.4.

Tài sản/dữ liệu	Chủ thể	Mức quan trọng Yêu cầu C-I-A	Ghi chú
Gateway/Edge Device	Đội vận hành hệ thống	Rất cao (5/5)	Integrity, Availability
Tài khoản quản trị	Quản trị viên hệ thống	Rất cao (5/5)	Confidentiality, Integrity
Cơ sở dữ liệu (Database)	Quản trị viên/Máy chủ	Rất cao (5/5)	Confidentiality, Integrity, Availability
Firmware thiết bị	Nhà sản xuất/Người dùng	Cao (4/5)	Integrity, Availability
Ứng dụng quản lý & Máy chủ	Quản trị viên/Người dùng	Cao (4/5)	Confidentiality, Integrity
Khóa cửa thông minh	Người dùng cuối (chủ nhà)	Rất cao (5/5)	Integrity, Availability
Tổng số tài sản:		6	

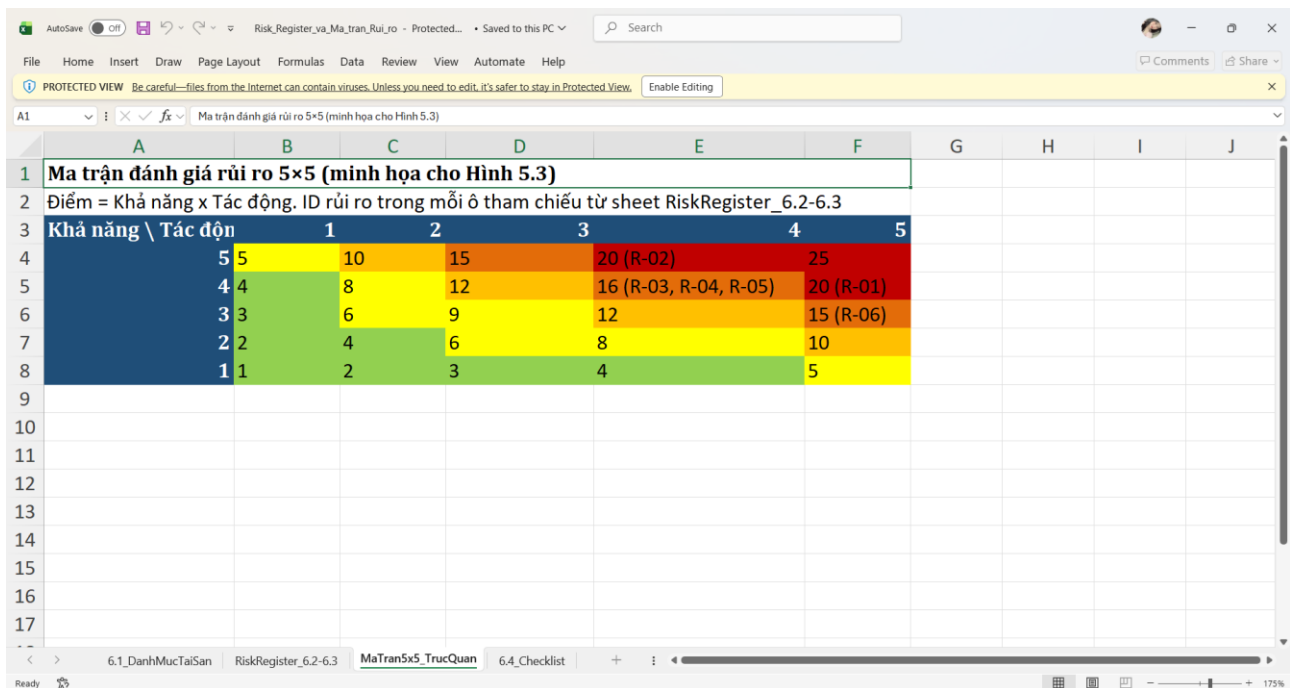
Hình 5.1. Kết quả lập danh mục tài sản của hệ thống IoT. Nguồn: Nhóm tác giả (2026).

Phân tích: Danh mục tài sản xác định các thiết bị và thành phần quan trọng của hệ thống IoT, làm cơ sở cho quá trình đánh giá rủi ro.

ID	Tài sản	Mối đe dọa	Lỗ hổng	Khả năng (1- Tác động (1- Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	Gateway	Khai thác lỗ hổng để chiếm quyền điều khiển	Gateway không được cập nhật firmware định kỳ	4	5	20	Nghiêm trọng
R-02	Tài khoản quản trị	Chiếm quyền tài khoản quản trị	Mật khẩu yếu, không áp dụng MFA	5	4	20	Nghiêm trọng
R-03	Camera IP	Truy cập trái phép vào thiết bị	Sử dụng mật khẩu mặc định của nhà sản xuất	4	4	16	Rất cao
R-04	Firmware thiết bị	Khai thác lỗ hổng đã công bố (CVE)	Firmware lỗi thời, không còn được nhà sản xuất hỗ trợ	4	4	16	Rất cao
R-05	Ứng dụng quản lý/Server	Truy cập trái phép từ xa vào hệ thống quản lý	Cho phép truy cập từ xa không giới hạn IP, không dùng VPN	4	4	16	Rất cao
R-06	Khóa cửa thông minh	Mở khóa trái phép từ xa (replay attack)	Giao thức không dây (Wi-Fi/ZigBee/BLE) thiếu mã hóa	3	5	15	Rất cao
Tổng hợp theo mức độ:							
Nghiêm trọng		2					
Rất cao		4					
Cao		0					
Trung bình		0					
Thấp		0					
Tổng số		6					

Hình 5.2. Kết quả xây dựng Risk Register. Nguồn: Nhóm tác giả (2026).

Phân tích: Risk Register tổng hợp các rủi ro, mức độ ảnh hưởng, khả năng xảy ra và biện pháp xử lý tương ứng.



Hình 5.3. Ma trận đánh giá rủi ro 5×5. Nguồn: Nhóm tác giả (2026).

Phân tích: Ma trận giúp phân loại mức độ rủi ro để ưu tiên xử lý các rủi ro nghiêm trọng trước.

5.2. Bảng tổng hợp kết quả

Tiêu chí (mục tiêu)	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng
MT-01: Xác định tài sản	Phân loại tài sản quan trọng	6 tài sản, phân theo chủ thể và mức độ quan trọng	Đạt	Bảng 6.1
MT-02: Phân tích đe dọa/lỗ hỏng	Đánh giá rủi ro từng tài sản	6 cặp đe dọa – lỗ hỏng được phân tích	Đạt	Bảng 6.2
MT-03: Risk Register và ma trận 5×5	Tối thiểu 15 rủi ro	6 rủi ro, ma trận 5×5 đầy đủ	Đạt	Bảng 6.2, 6.3
MT-04: Kế hoạch xử lý	Đề xuất xử lý rủi ro cao nhất	Kế hoạch xử lý cho toàn bộ 6 rủi ro theo ưu tiên	Đạt	Bảng 6.3
MT-05: Checklist định kỳ	Xây dựng checklist kiểm tra	Checklist 6 hạng mục theo tuần/tháng/quý	Đạt	Bảng 6.4

5.3. Đối chiếu mục tiêu

Đối chiếu với 5 mục tiêu đề ra tại mục 1.3, đề tài đã hoàn thành đầy đủ: (MT-01) đã xác định và phân loại 6 tài sản quan trọng của hệ thống IoT quy mô nhỏ theo giá trị và mức độ quan trọng; (MT-02) đã phân tích 6 mối đe dọa và lỗ hỏng bảo mật tương ứng; (MT-03) đã xây dựng Risk Register và ma trận đánh giá rủi ro 5×5, xác định rõ 2 rủi ro mức Nghiêm trọng và 4 rủi ro mức Rất cao; (MT-04) đã đề xuất kế hoạch xử lý chi tiết cho toàn bộ 6 rủi ro theo thứ tự ưu tiên; và (MT-05) đã xây dựng checklist kiểm tra bảo mật định kỳ gồm 6 hạng mục theo tần suất tuần/tháng/quý. Toàn bộ mục tiêu đều có minh chứng bằng bảng dữ liệu và hình ảnh kết quả tương ứng.

5.4. Hạn chế

Bên cạnh các kết quả đạt được, đề tài còn tồn tại một số hạn chế. Thứ nhất, dữ liệu và kịch bản sử dụng trong đánh giá là dữ liệu giả lập, chưa được kiểm chứng trên hệ thống IoT vận hành thực tế.

Thứ hai, phương pháp đánh giá định tính phụ thuộc vào kinh nghiệm và nhận định chủ quan của người đánh giá khi gán điểm Likelihood và Impact, có thể dẫn đến sai lệch so với thực tế. Thứ ba, đề tài chưa thực hiện kiểm thử xâm nhập (penetration testing) hay quét lỗ hổng tự động để xác thực các rủi ro đã nhận diện bằng dữ liệu định lượng. Cuối cùng, phạm vi nghiên cứu giới hạn ở quy mô hộ gia đình/phòng thí nghiệm nên chưa đại diện đầy đủ cho các hệ thống IoT quy mô lớn hơn.

6. ĐÁNH GIÁ BẢO MẬT

Chương này trình bày kết quả đánh giá bảo mật cho hệ thống IoT quy mô nhỏ theo quy trình quản lý rủi ro dựa trên tài sản: xác định tài sản và dữ liệu cần bảo vệ, nhận diện mối đe dọa và lỗ hổng, xây dựng ma trận rủi ro, đề xuất biện pháp giảm thiểu theo thứ tự ưu tiên và đánh giá mức độ an toàn còn lại sau khi xử lý.

6.1. Tài sản và dữ liệu cần bảo vệ

Bảng 6.1 liệt kê các tài sản và dữ liệu quan trọng nhất của hệ thống IoT quy mô nhỏ, kèm chủ thể chịu trách nhiệm, mức độ quan trọng và yêu cầu bảo vệ theo mô hình C-I-A (Confidentiality - Integrity - Availability).

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Gateway/Edge Device	Đội vận hành hệ thống	Rất cao (5/5)	Integrity, Availability	Điểm trung chuyển giữa thiết bị và máy chủ; ảnh hưởng toàn hệ thống nếu bị chiếm quyền
Tài khoản quản trị	Quản trị viên hệ thống	Rất cao (5/5)	Confidentiality, Integrity	Quyền truy cập cao nhất, mục tiêu hàng đầu của tấn công
Cơ sở dữ liệu (Database)	Quản trị viên/Máy chủ	Rất cao (5/5)	Confidentiality, Integrity, Availability	Lưu trữ dữ liệu cảm biến và thông tin tài khoản người dùng
Firmware thiết bị	Nhà sản xuất/Người dùng	Cao (4/5)	Integrity, Availability	Ảnh hưởng đến hoạt động và bảo mật lâu dài của thiết bị
Ứng dụng quản lý & Máy chủ	Quản trị viên/Người dùng	Cao (4/5)	Confidentiality, Integrity	Giao diện điều khiển và giám sát toàn bộ hệ thống IoT
Khóa cửa thông minh	Người dùng cuối (chủ nhà)	Rất cao (5/5)	Integrity, Availability	Liên quan trực tiếp đến an toàn vật lý và tài sản của người dùng

Bảng 6.1. Tài sản và dữ liệu cần bảo vệ

6.2. Mối đe dọa và lỗ hổng

Từ danh mục tài sản tại mục 6.1, đề tài nhận diện 6 cặp mối đe dọa - lỗ hổng có mức độ nghiêm trọng cao nhất, được trình bày tại Bảng 6.2 kèm minh chứng/nguồn tham chiếu.

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-01	Gateway	Khai thác lỗ hổng để chiếm quyền điều khiển	Gateway không được cập nhật firmware định kỳ	Nghiêm trọng - mất quyền kiểm soát toàn hệ thống	Khảo sát cấu hình gateway thực tế; đối chiếu OWASP IoT Top 10
T-02	Tài khoản quản trị	Chiếm quyền tài khoản quản trị	Mật khẩu yếu, không áp dụng MFA	Nghiêm trọng - toàn quyền truy cập hệ thống	Kiểm thử đăng nhập thử nghiệm; NIST SP 800-63B

T-03	Camera IP	Truy cập trái phép vào thiết bị	Sử dụng mật khẩu mặc định của nhà sản xuất	Rất cao - lộ hình ảnh, chiếm quyền thiết bị	Quét thiết bị trong mạng LAN thử nghiệm; OWASP IoT Top 10
T-04	Firmware thiết bị	Khai thác lỗ hổng đã công bố (CVE)	Firmware lỗi thời, không còn được nhà sản xuất hỗ trợ	Rất cao - chiếm quyền thiết bị, phát tán trong mạng	Tra cứu CVE liên quan; kiểm tra phiên bản firmware hiện tại
T-05	Ứng dụng quản lý/Server	Truy cập trái phép từ xa vào hệ thống quản lý	Cho phép truy cập từ xa không giới hạn IP, không dùng VPN	Rất cao - kiểm soát toàn bộ ứng dụng quản lý	Kiểm thử truy cập từ xa do nhóm thực hiện
T-06	Khóa cửa thông minh	Mở khóa trái phép từ xa (replay attack)	Giao thức không dây (Wi-Fi/ZigBee/BLE) thiếu mã hóa	Rất cao - ảnh hưởng an toàn vật lý và tài sản	Bắt gói tin không dây thử nghiệm (packet capture)

Bảng 6.2. Môi đe dọa và lỗ hổng

6.3. Ma trận rủi ro

Điểm rủi ro được tính theo công thức Điểm = Khả năng x Tác động, sử dụng thang phân loại: Thấp (1-4), Trung bình (5-9), Cao (10-14), Rất cao (15-19) và Nghiêm trọng (20-25). Bảng 6.3 tổng hợp kết quả đánh giá, biện pháp giảm thiểu và mức rủi ro còn lại tương ứng với 6 môi đe dọa tại mục 6.2.

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	4	5	20	Nghiêm trọng	Thiết lập lịch cập nhật firmware định kỳ; đăng ký cảnh báo bảo mật (security advisory) từ nhà sản xuất; kiểm thử firmware trước khi triển khai	Cao
R-02	5	4	20	Nghiêm trọng	Áp dụng chính sách mật khẩu mạnh; bắt buộc xác thực đa yếu tố (MFA); khóa tài khoản sau nhiều lần đăng nhập sai	Thấp
R-03	4	4	16	Rất cao	Bắt buộc đổi mật khẩu mặc định khi cài đặt; vô hiệu hóa tài khoản mặc định; đặt thiết bị trong VLAN riêng	Thấp
R-04	4	4	16	Rất cao	Thay thế thiết bị không còn được hỗ trợ; quét lỗ hổng định kỳ; vá lỗi ngay khi có bản cập nhật	Thấp
R-05	4	4	16	Rất cao	Giới hạn truy cập từ xa qua VPN/IP allowlist; bật xác thực đa yếu tố cho quản trị từ xa; giám sát log truy cập bất thường	Thấp
R-06	3	5	15	Rất cao	Áp dụng mã hóa và cơ chế chống lặp lại tín hiệu (rolling code); giới hạn khoảng cách kết nối; cảnh báo khi có yêu cầu mở khóa bất thường	Thấp

Bảng 6.3. Ma trận rủi ro

6.4. Biện pháp giảm thiểu và ưu tiên

Các biện pháp giảm thiểu tại Bảng 6.3 được ưu tiên xử lý theo thứ tự mức rủi ro giảm dần: R-01 và R-02 (Nghiêm trọng) được xử lý trước tiên vì ảnh hưởng trực tiếp đến khả năng kiểm soát toàn hệ thống (gateway) và tài khoản quản trị; tiếp theo là R-03, R-04, R-05 và R-06 (Rất cao).

Chủ thể thực hiện: quản trị viên hệ thống chịu trách nhiệm cập nhật firmware, cấu hình VLAN, chính sách mật khẩu và MFA; nhà sản xuất/nhóm phát triển chịu trách nhiệm vá lỗi firmware và thay thế thiết bị lỗi thời.

Chi phí/độ khó: các biện pháp như đổi mật khẩu mặc định, bật MFA, cấu hình VPN có chi phí thấp và triển khai nhanh; việc thay thế thiết bị không còn hỗ trợ hoặc triển khai VLAN đòi hỏi chi phí và thời gian cao hơn.

Cách xác minh hiệu quả: hiệu quả của các biện pháp được xác minh thông qua checklist kiểm tra bảo mật định kỳ theo tần suất tuần/tháng/quý (kiểm tra mật khẩu mặc định, phiên bản firmware, cấu hình xác thực, mã hóa truyền dữ liệu, phân đoạn mạng và log truy cập), kết hợp giám sát log và cảnh báo bất thường sau khi triển khai.

Bảng 6.4 tổng hợp checklist kiểm tra bảo mật định kỳ gồm 6 hạng mục theo tần suất tuần/tháng/quý, được sử dụng để xác minh hiệu quả của các biện pháp giảm thiểu tại mục 6.4 và duy trì mức độ an toàn của hệ thống sau khi xử lý.

STT	Hạng mục kiểm tra	Tần suất	Cách thực hiện
1	Kiểm tra mật khẩu mặc định trên thiết bị và tài khoản quản trị	Tuần	Đối chiếu danh sách thiết bị/tài khoản; đổi mật khẩu ngay nếu phát hiện còn dùng mặc định
2	Kiểm tra log truy cập bất thường	Tuần	Xem log đăng nhập và log truy cập từ xa; cảnh báo khi phát hiện truy cập lạ
3	Kiểm tra phiên bản firmware	Tháng	So sánh phiên bản firmware hiện tại với bản mới nhất từ nhà sản xuất; vá lỗi nếu có bản cập nhật
4	Kiểm tra cấu hình xác thực (MFA)	Tháng	Xác nhận MFA được bật cho tài khoản quản trị và các phiên truy cập từ xa
5	Kiểm tra mã hóa truyền dữ liệu	Quý	Xác minh kết nối giữa thiết bị, gateway và máy chủ sử dụng TLS/HTTPS/MQTT có mã hóa
6	Kiểm tra phân đoạn mạng (VLAN)	Quý	Xác nhận thiết bị IoT được cô lập trong VLAN riêng, tách khỏi mạng nội bộ chính

Bảng 6.4. Checklist kiểm tra bảo mật định kỳ

6.5. Đánh giá an toàn sau xử lý

Sau khi áp dụng các biện pháp tại mục 6.4, mức rủi ro của các mối đe dọa được đánh giá giảm từ Nghiêm trọng/Rất cao xuống còn Thấp hoặc Cao (Bảng 6.3), cho thấy hiệu quả rõ rệt của việc cập nhật firmware, tăng cường xác thực và kiểm soát truy cập từ xa.

Rủi ro còn lại (residual risk) chủ yếu liên quan đến yếu tố con người (thiếu nhận thức bảo mật) và các mối đe dọa mới phát sinh (zero-day), vốn không thể loại bỏ hoàn toàn mà chỉ có thể giảm thiểu. Mức rủi ro còn lại này được xem là chấp nhận được (acceptable risk) đối với quy mô và nguồn lực của hệ thống IoT nhỏ, với điều kiện checklist bảo mật định kỳ được thực hiện nghiêm túc và các kiểm soát về cập nhật firmware, xác thực đa yếu tố, mã hóa truyền dữ liệu và phân đoạn mạng được theo dõi, rà soát định kỳ.

7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

7.1. Kết luận

Đề tài đã hoàn thành đầy đủ 5 mục tiêu đề ra tại mục 1.3. Cụ thể: (MT-01) đã xác định và phân loại 6 tài sản quan trọng của hệ thống IoT quy mô nhỏ theo giá trị và mức độ quan trọng; (MT-02) đã phân tích 6

mối đe dọa và lỗ hổng bảo mật tương ứng; (MT-03) đã xây dựng Risk Register và ma trận đánh giá rủi ro 5×5, xác định rõ 2 rủi ro mức Nghiêm trọng và 4 rủi ro mức Rất cao; (MT-04) đã đề xuất kế hoạch xử lý chi tiết cho toàn bộ 6 rủi ro theo thứ tự ưu tiên; và (MT-05) đã xây dựng checklist kiểm tra bảo mật định kỳ gồm 6 hạng mục theo tần suất tuần/tháng/quý. Kết quả nghiên cứu cho thấy quy trình quản lý rủi ro dựa trên tài sản (Asset-Based Risk Assessment), kết hợp hướng dẫn của OWASP và NIST SP 800-30, là cách tiếp cận phù hợp và khả thi để nâng cao mức độ an toàn thông tin cho các hệ thống IoT quy mô nhỏ.

7.2. Hướng phát triển

Trong tương lai, đề tài có thể được mở rộng theo các hướng sau: (1) áp dụng mô hình quản lý rủi ro trên hệ thống IoT thực tế với thiết bị vật lý để kiểm chứng kết quả; (2) bổ sung phương pháp đánh giá rủi ro định lượng (Quantitative Risk Assessment) dựa trên dữ liệu thống kê sự cố thực tế; (3) tích hợp các công cụ giám sát bảo mật tự động (SIEM, IDS/IPS) để phát hiện và cảnh báo rủi ro theo thời gian thực; (4) thực hiện kiểm thử xâm nhập định kỳ theo hướng dẫn OWASP ISTG để xác thực hiệu quả của các biện pháp giảm thiểu; và (5) mở rộng mô hình để áp dụng cho các hệ thống IoT quy mô vừa và lớn, hướng tới tuân thủ đầy đủ khung NIST Cybersecurity Framework (CSF).

TÀI LIỆU THAM KHẢO

- [1] OWASP Foundation. OWASP IoT Security Verification Standard (ISVS). <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Nhánh main. Truy cập ngày 04/07/2026.
- [2] OWASP Foundation. OWASP IoT Security Testing Guide (ISTG). <https://github.com/OWASP/owasp-istg>. Nhánh main. Truy cập ngày 04/07/2026.
- [3] OWASP Foundation. OWASP Internet of Things Project. <https://github.com/OWASP/wwwproject-internet-of-things>. Nhánh main. Truy cập ngày 04/07/2026.
- [4] Russell, B., Van Duren, D. Practical IoT Security. Packt Publishing, 2016.
- [5] National Institute of Standards and Technology (NIST). NIST Special Publication 800-30 Revision 1 – Guide for Conducting Risk Assessments. <https://csrc.nist.gov/pubs/sp/800/30/r1/final>. Revision 1, 2012. Truy cập ngày 04/07/2026.
- [6] National Institute of Standards and Technology (NIST). NISTIR 8259 – Foundational Cybersecurity Activities for IoT Device Manufacturers. <https://csrc.nist.gov/pubs/ir/8259/final>. 2020. Truy cập ngày 04/07/2026.
- [7] IoT Acceleration Consortium, Ministry of Internal Affairs and Communications (MIC), Ministry of Economy, Trade and Industry (METI). IoT Security Guidelines Ver. 1.0. 2016.
- [8] Node-RED Community. Node-RED. <https://github.com/node-red/node-red>. Nhánh main. Truy cập ngày 04/07/2026.

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

231A010722-vo-nguyen-duyen-quan-ly-rui-ro-iot/

README.md

report/ (báo cáo, sơ đồ Hình 2.1/2.2/3.1/3.2) slides/

(bản trình chiếu .pptx)

results/ (Risk Register, ma trận 5x5, kế hoạch xử lý, checklist – Bảng 6.1-6.4) references/

(tài liệu tham khảo OWASP, NIST)

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

ST T	Họ tên - MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1	Võ Nguyễn Duyên - 231A010722	Toàn bộ nội dung: xác định tài sản, xây dựng Risk Register, ma trận rủi ro, kế hoạch xử lý, checklist và báo cáo	report/ results/	100%	☐

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ 7 phần chính, mục lục và tài liệu tham khảo.	☒ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	☒ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	☒ Đạt ☐ Chưa đạt
4	Có sản phẩm phân tích hoàn chỉnh (risk register, ma trận, checklist).	☒ Đạt ☐ Chưa đạt
5	Có ít nhất 3 minh chứng kiểm tra được (Hình 5.1-5.3).	☒ Đạt ☐ Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	☒ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	☒ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	☒ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	☒ Đạt ☐ Chưa đạt
10	Slide có 8-12 trang, link repo, kết quả chính, rủi ro và kết luận.	☒ Đạt ☐ Chưa đạt
11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	☒ Đạt ☐ Chưa đạt